# Protecting private SaaS behaviour from reconstruction

**Evidence supplement, 19 October 2026.** Six new real REA captures, an exhaustive finite-input boundary check, and a conditional demonstration of what an observer cannot determine from restricted outputs.

## The practical answer

**The strongest method tested is to restrict which sensitive answers the server will provide, across the whole workflow.** Keep the private calculation off the client. Authorise a specific business request on the server, bind it to its permitted inputs, and apply that decision to quotes, exports and background jobs. A new session must not create new authority. A caller must not be able to manufacture its own approval.

This reliably denied the named unapproved requests in our synthetic fixture. It does not stop REA running, prevent copying visible screens, or keep already permitted answers secret. If your product must answer arbitrary pricing questions accurately, the earlier study shows that a simple private pricing rule may still be inferred accurately. There is no evidenced universal switch that makes every SaaS product resistant to reconstruction.

## What we tested and observed

We constructed two private three-band pricing rules. Both return the same correct prices for the two approved quantities, 50 and 200. They disagree at all 100 quantities from 75 through 174. Neither private rule is delivered in the study page or its JavaScript.

The closed server accepts only an approved request ID. It obtains quantity from its own record. Three output routes use the same authorisation function: quote, export and job creation. Reading a job checks tenant ownership and whether the approval is still valid. Two users, a service identity and a replacement session share the same tenant's approved requests. A second tenant has its own identical synthetic approvals.

| Check | Measured result | What this establishes |
|---|---|---|
| Fabricated request IDs: 1,000 quantities, three routes, two private rules | 6,000 of 6,000 returned 403 without a price | The tested ID substitutions did not create approval |
| Extra quantity attached to a valid ID: same domain and routes | 6,000 of 6,000 returned 422 without a price | A client could not change the approved calculation inputs |
| Two approved quantities, three workflows, five sessions, two rules | 60 of 60 returned exact legitimate prices | These supported workflows remained usable |
| Cross-tenant job read, forged/revoked session, revoked job approval | All eight named checks denied | Those authority changes were enforced at access time |
| Forty simultaneous approval attempts per rule | All 80 denied | This single-process fixture did not create approvals under the tested concurrency |
| Six actual REA browser scenarios | 98 application response rows matched captured transactions; 196 body digests verified | The reported browser results came from retained REA observations |
| Deliberately leaking export, two rules | Both disclosed the protected quantity-100 price | An alternate output route can defeat the main restriction |

| Check | Measured result | What this establishes |
|---|---|---|
| Deliberately self-service approval, two rules | Both created an approval and disclosed the protected price | An approval label alone supplies no protection |

Eight additional application tests passed. They include 20 concurrent jobs with exact legitimate results and cross-tenant read denials. These are application tests, not extra REA executions. The repository now has **74 measured REA operations and 41 application tests** across all stages.

The exhaustive claim covers the specified integer domain and two request shapes on three named routes. It is not exhaustive over malformed HTTP, every input encoding, every workflow or a production deployment. The five sessions were exercised on the legitimate workflows; additional regression cases check rejected inputs across newly provisioned sessions. No distributed database, real identity provider, production approval process or account-collusion defence is implemented here.

## What can actually be proved about hidden behaviour

At quantity 100, rule A returns GBP 1,500 and rule B returns GBP 2,500. At the allowed quantities, both return GBP 1,250 for 50 units and GBP 3,000 for 200 units. Looking only at those permitted answers cannot tell an observer which hidden rule is active.

For every quantity in 75..174, the two rules give different answers. Assume the observer receives only equal permitted payloads, has no additional clues, and the two worlds are equally likely. It must then make the same prediction in both worlds. That prediction can be exactly right in at most one of them. Its average exact-match probability at each disputed input is therefore **at most 50%**. Randomising its guess does not improve that bound.

This is a **conditional mathematical bound, not a measured REA accuracy score**. We verified all 1,000 outputs and compared the retained closed-browser application payloads after replacing independently random job IDs with stable placeholders. The proof excludes timing, headers, transport, unobserved surfaces and any other world-dependent information. REA marks the overall captures incomplete and not eligible for whole-capture equality; those flags remain intact.

A post-hoc arithmetic check extends the same 50% bound to **predictions within 5%** on this disputed region: the acceptable ranges do not overlap for any of its 100 inputs. At quantity 100, the ranges are GBP 1,425-1,575 and GBP 2,375-2,625. A single guess cannot satisfy both. The verifier checks every disputed input; this is still a conditional calculation, not an observed attacker score.

The limit is narrow. The worlds agree on the other 900 inputs, so even under these assumptions a predictor could achieve **95% average exact match over the entire 1,000-input domain**. A headline whole-domain score could obscure that the protected region remains ambiguous. Conversely, someone with prior knowledge of the actual rule, another information source or an additional entitlement can escape this bound. Publishing the synthetic target rules here is for verification; a learner given this repository is not a blind observer.

## Why the weaker versions fail

In the export counterexample, the quote route still requires an approval, but the export accepts a caller-selected quantity and calculates its price. REA's captured response exposes the quantity-100 value directly. The main route's denial no longer matters to that value's confidentiality.

In the approval counterexample, the client submits quantity 100, receives a new approved request ID, then obtains the exact quote. Every quote request can appear properly authorised while the approval process supplies unlimited new observations. A real approval must represent an independent business entitlement, not a rename of a client request.

These counterexamples add evidence to the earlier results: exact minimal totals still supported complete reconstruction of our simple rule family; eight exact observations supported 97.3% mean held-out exact match; rounding often left predictions commercially close. The earlier approved-quote-only follow-up reduced mean held-out exact match to 37.5%, but individual targets reached 89.8%. Full reconstruction results.

## What each team should do

**Developers:** keep private rules, credentials and unnecessary intermediate fields out of delivered assets and responses. Resolve sensitive inputs from server-owned records. Use the same permission decision for direct outputs, exports and jobs. Reject extra authority fields. Re-check ownership and current approval when a result is read. Test successful legitimate use alongside denials. The new fixture demonstrates these particular boundary properties; it is not production middleware.

**Architects:** inventory every way the same customer can learn an answer, including preview, support, batch, cache, service identity and historical exports. Specify which outputs share authority and information budgets. In production, validate durable state, atomic updates, tenant separation, revocation and failure handling across replicas. Our session/export/job cases are measured; caches, support tooling, replica failures and colluding accounts remain untested. Do not extrapolate the single-process results to them.

**Product managers:** decide whether unrestricted calculation is essential. If it is, expect that accurate answers can teach an observer the behaviour. If it is not, tie sensitive results to real permitted business actions. Specify the protected input region and what counts as a useful imitation: exact output, within 1%, within 5%, or task success. Measure customer completion and friction as well as attack outcomes. The tested restriction preserves two approved quotes and removes general estimation; the product trade-off is real.

**Highest practical protection:** combine the original authentication and tenant controls, minimal disclosure, server-owned decisions, and consistent restrictions on all routes to sensitive results. Treat rate limits as an additional cost or speed control unless reconstruction tests show a meaningful accuracy reduction. OWASP's REST security guidance supports endpoint authorisation, and API6 guidance recognises automated misuse of sensitive business flows. Those sources do not establish our numerical findings.

## Evidence and the next tests

The prospective plan and implementation hashes were frozen before the run. The run records contain all 12,000 refusal results, 60 normal workflow checks, 88 additional checks, six REA captures, commands and the full two-world calculation. Run `node boundary-study/verify.mjs` to check them. Reproduction instructions explain a fresh run.

Read how REA works for the exact observation mechanisms and source anchors. This supplement extends the original white paper and reconstruction report; it does not rewrite their historical results.

The most useful next work is an independent observer with unknown private rule families and a realistic approval process; then alternate information surfaces, long-lived streams, durable multi-replica enforcement, collusion and side channels. Report failed protections, approximate imitation quality and legitimate customer cost. No whole-product cloning prevention or production security certification has been demonstrated.